

Nombre: Javier Gabriel Pinto Chara	Tarea # 2
---------------------------------------	-----------

ANÁLISIS DE RIESGOS – Departamento de TI (Caso de estudio)

1) DETERMINAR EL ALCANCE

Unidad analizada: Departamento de Tecnologías de Información de una entidad financiera.

Procesos considerados: administración de servidores y redes, seguridad de endpoints, acceso remoto, gestión de respaldos y continuidad operativa (DR en nube).

Alcance temporal: situación actual descrita en los puntos 1-8 del enunciado.

2) IDENTIFICAR ACTIVOS

DISPOSITIVOS

ID	Activo / Descripción	Ubicación	Responsable
ID_1	Servidores, almacenamiento y equipos de red (en operación 1 año)	CPD principal	Jefe de TI
ID_5	Firewall perimetral con SSH (puerto 22) habilitado para acceso remoto	Perímetro	Admin de Red
ID_6	PCs de funcionarios (antivirus versión gratuita)	Oficinas	Soporte TI

SOFTWARE Y APLICACIONES

ID	Activo / Descripción	Ubicación	Responsable
ID_2	Sistema de gestión nuevo con controles de seguridad	Servidores de aplicación/BD	Jefe de Sistemas
ID_3	Tablas/bitácoras de auditoría del sistema (deshabilitadas)	BD del sistema	Seguridad de la Información

PERSONAL

ID	Activo / Descripción	Ubicación	Responsable
ID_7	Practicantes (BYOD) con acceso a la red	Red interna	Jefe de TI

TELECOMUNICACIONES

ID	Activo / Descripción	Ubicación	Responsable
ID_4	Backups (10 copias) con resguardo a >25 km	Sitio alternativo	Admin de Backups
ID_8	Servicio en la nube para DR 24/7 (virtualización mínima)	Nube	Jefe de TI

INSTALACIONES

ID	Activo / Descripción	Ubicación	Responsable
----	----------------------	-----------	-------------

CPD	Centro de procesamiento de datos principal	Edificio principal	Infraestructura
------------	--	--------------------	-----------------

3) VALORAR ACTIVOS (D, I, C)

Escala 1–5. Importancia = (Disponibilidad + Integridad + Confidencialidad) / 3.

ID	Activo	Disp	Integr	Conf	Importancia
ID_1	DISPOSITIVOS/Servidores	5	5	4	4.6667
ID_2	SOFTWARE Y APLICACIONES/Sistema de gestión	5	5	4	4.6667
ID_3	SOFTWARE Y APLICACIONES/Bitácoras de auditoría	4	5	5	4.6667
ID_4	TELECOMUNICACIONES/Backups y sitio alterno	5	4	4	4.3333
ID_5	DISPOSITIVOS/Firewall	4	4	3	3.6667
ID_6	DISPOSITIVOS/Endpoints funcionarios	4	3	3	3.3333
ID_7	PERSONAL/BYOD practicantes	3	3	3	3.0000
ID_8	TELECOMUNICACIONES/DR en nube	4	4	4	4.0000

4) IDENTIFICAR AMENAZAS

ID	Amenaza (según lista oficial)	Activo
A1	ATAQUES INTENCIONADOS → Acceso no autorizado/fuerza bruta a SSH (puerto 22).	ID_5
A2	MALWARE/CÓDIGO MALICIOSO → Infecciones en endpoints.	ID_6
A3	ERRORES Y FALLOS NO INTENCIONADOS → Fuga/manipulación por NO registrar auditoría.	ID_3
A4	ATAQUES INTENCIONADOS / ERRORES → Exfiltración o propagación vía BYOD practicantes.	ID_7

5) IDENTIFICAR VULNERABILIDADES

ID	Vulnerabilidad (según lista oficial)	Activo
V1	Servicio expuesto/configuración insegura; credenciales débiles en SSH.	ID_5
V2	Protección endpoint limitada (antivirus gratuito sin EDR).	ID_6
V3	Bitácoras y tablas de auditoría deshabilitadas por capacidad.	ID_3
V4	Dispositivos no gestionados (BYOD) sin NAC/MDM ni endurecimiento.	ID_7

6) EVALUAR EL RIESGO

Riesgo = Probabilidad × Impacto. Impacto = promedio(Financiero, Imagen, Operativo).

ACTIVO: SOFTWARE Y APLICACIONES

N°	Descripción del riesgo	Prob.	Financ.	Imagen	Operativo	Impacto (avg)	Riesgo
----	------------------------	-------	---------	--------	-----------	---------------	--------

1	Fuga o manipulación sin trazabilidad por auditoría deshabilitada.	4	4	5	4	4.3333	17.3333
---	---	---	---	---	---	--------	---------

Riesgo promedio: 17.3333

ACTIVO: DISPOSITIVOS

N°	Descripción del riesgo	Prob.	Financ.	Imagen	Operativo	Impacto (avg)	Riesgo
1	Acceso no autorizado vía fuerza bruta/exposición de SSH (22).	4	4	4	4	4.0000	16.0000
2	Infección por malware en PCs por protección insuficiente.	4	3	3	4	3.3333	13.3333

Riesgo promedio: 14.6667

ACTIVO: PERSONAL

N°	Descripción del riesgo	Prob.	Financ.	Imagen	Operativo	Impacto (avg)	Riesgo
1	Ingreso de BYOD no gestionado (malware/exfiltración).	3	3	4	4	3.6667	11.0000

Riesgo promedio: 11.0000

ACTIVO: TELECOMUNICACIONES

N°	Descripción del riesgo	Prob.	Financ.	Imagen	Operativo	Impacto (avg)	Riesgo
1	Pérdida de disponibilidad si DR en nube no se prueba periódicamente.	2	4	3	4	3.6667	7.3333

Riesgo promedio: 7.3333

7) MATRIZ DE RIESGO (Probabilidad vs Impacto)

Ubicación de los riesgos según la combinación Probabilidad–Impacto (1 a 5).

Prob. \ Impacto	1	2	3	4	5
5					
4			R2 Malware endpoints	R1 SSH expuesto; R3 Sin auditoría/logs	
3				R4 BYOD practicantes	
2				R5 DR no probado	
1					

8) TRATAR EL RIESGO

ACTIVO	RIESGO IDENTIFICADO	CONTRAMEDIDA
DISPOSITIVOS	Acceso no autorizado por SSH expuesto.	Restringir SSH mediante VPN/2FA, claves, listas por IP, IDS/IPS y bloqueo por fuerza bruta.
DISPOSITIVOS	Infecciones por malware en endpoints.	Licenciar EDR/antivirus corporativo, actualización automática, control de aplicaciones/USB y capacitación.
SOFTWARE Y APLICACIONES	Fuga/manipulación por auditoría deshabilitada.	Habilitar y retener logs con archivado/compresión y SIEM; revisiones periódicas y segregación de funciones.
PERSONAL	BYOD no gestionado (practicantes).	Política BYOD con NAC/MDM, segmentación, cuentas temporales, antivirus corporativo y privilegios mínimos.